

Lahore Garrison University
Software Verification & Validation

Name: Ahmed Saghir

Roll num: Fa-23/BS-SE/087

Submitted to: Miss Jaweria

Section A – Validation Checklist Engineering

Q1 Measurable Validation Criteria

We need to take what the stakeholders want and turn it into things we can actually test and measure:

1. Secure Login

The password has to be locked up like with bcrypt or sha256

If someone tries to login five times and fails the system has to block them

The system has to let us know if the login is okay or not in two seconds or less

2. Transaction Accuracy

The amount of money that is moved around has to match what is in the database every single time

We cannot have two transactions that're the same

The balance has to be updated perfectly every time

3. Session Timeout

If someone is not doing anything on the site for ten minutes their session has to end

The system has to log them out

They have to login again after the session times out

4. Mobile Responsiveness

The site has to look good on screens from 320 pixels, to 1440 pixels

We cannot have a situation where someone has to scroll sideways on their mobile phone

The site has to load in three seconds or less even on a 4G connection

5. Audit Logging

Every single transaction has to be written down in a log

The log has to have the time it happened the users ID and what they did

The logs have to be set in stone we cannot change them. Delete them once they are made

Q1 (2): Validation Checklist Table

ID	Feature	Validation Criteria	Test Method	Expected Result	Status
1	Secure Login	Encrypt password + 5 failed attempts lock	Login test	Account locked after 5 attempts	Pass/Fail

ID	Feature	Validation Criteria	Test Method	Expected Result	Status
2	Transaction Accuracy	Balance must update correctly	Transaction simulation	Correct updated balance	Pass/Fail
3	Session Timeout	Logout after 10 min inactivity	Idle test	Auto logout occurs	Pass/Fail
4	Mobile UI	Responsive layout	Device testing	UI fits all screens	Pass/Fail
5	Audit Logging	All actions logged	Log inspection	Logs stored correctly	Pass/Fail

Section B – CI Validation

Q2 (1): CI Validation Explanation

There are validation checkpoints in the CI pipeline.

The CI pipeline does this:

- Every time someone pushes code it triggers the automated pipeline.
- The code is then tested using unit tests and integration tests.
- Security checks also run automatically this includes things like OWASP ZAP or linters.
- After each run reports are generated.
- The artifacts are stored this is for audit and compliance.

The main purpose of the CI validation is:

- To find bugs on.
- To make sure the security is validated all the time.
- To prove that we are complying with the rules.
- To document everything automatically this is what the CI validation does.

CI validation is important, for CI pipeline the CI validation is used for CI pipeline and the goal of the CI validation is to support the CI pipeline.

Q2 (2): GitHub Actions Workflow

Section C – Security Validation

Q3 (1): Role of Security Validation

The Security Validation is very important. It does a things. Security Validation makes sure that the software is checked for weaknesses before it is used.

It also checks if the software meets all the security requirements.

The Security Validation helps protect the software against attacks like SQL injection and XSS.

It also reduces the chance of people getting into the software and stealing data.

Q3 (2): Three Structural Vulnerabilities

1. SQL Injection

This is when a bad person tries to change the way the database works.

For example they can use ' OR 1=1 -- to get into the database.

This can let them see or delete data from the database.

2. Cross-Site Scripting (XSS)

This is when someone puts code into a website.

This bad code can steal information, like cookies or session data from people who use the website.

3. Broken Authentication

This is when the system that checks who can use the software is not strong.

It can let bad people get into the system by guessing passwords or taking over someone Session.

Q3 (3): OWASP ZAP Workflow for Security Validation (2 Marks)

Introduction to OWASP ZAP

OWASP ZAP (Zed Attack Proxy) is an open-source security testing tool used to identify vulnerabilities in web applications.

Official Website:

[OWASP ZAP Official Website](https://owasp.org/zap/)

Step 1: Target Configuration

1. Open OWASP ZAP.
2. Enter the target URL of the demo web application.
3. Example target:

http://testphp.vulnweb.com

4. Add the application to the scope for testing.

Purpose:

This step tells OWASP ZAP which application should be scanned.

Step 2: Passive Scanning

Passive scanning automatically analyzes the traffic between the browser and the web application without attacking the system.

OWASP ZAP checks:

- Missing security headers
- Information disclosure
- Cookie security issues
- Weak configurations

Advantages:

- Safe testing
- No damage to application
- Fast vulnerability detection

Step 3: Active Scanning

Active scanning performs real attacks on the target application to identify vulnerabilities.

OWASP ZAP tests for:

- SQL Injection

- Cross-Site Scripting (XSS)
- Broken Authentication
- Directory traversal

Process:

1. Right-click target
2. Select:

Attack → Active Scan

3. Start scanning

Step 4: Vulnerability Identification

After scanning, OWASP ZAP displays vulnerabilities in the Alerts section.

Each alert contains:

- Vulnerability name
- Description
- Risk level
- Evidence
- Suggested solution

Step 5: Severity Classification

OWASP ZAP classifies vulnerabilities according to severity.

Severity Level	Description
High	Critical vulnerabilities that can seriously damage the system
Medium	Important vulnerabilities requiring fixes
Low	Minor security weaknesses
Informational	Security recommendations and observations

Step 6: Evidence Documentation

The validation evidence should include:

- OWASP ZAP HTML/PDF scan reports
- Screenshots of vulnerabilities
- Logs and alerts
- Severity classification
- Suggested mitigation strategies

Example Evidence:

- SQL Injection Alert Screenshot
- XSS Detection Report
- Security Header Missing Logs

Vulnerability Findings Table

Vulnerability	Severity	Description	Mitigation
SQL Injection	High	Database query manipulation	Use parameterized queries
Cross-Site Scripting	Medium	Script injection in browser	Input sanitization
Missing Security Headers	Low	Weak HTTP security configuration	Add security headers

Expected Deliverables

The following deliverables should be included in the assignment submission:

1. OWASP ZAP Scan Report
2. Vulnerability Findings Table
3. Severity Classification

- 4. Screenshots/Evidence Logs
- 5. Suggested Mitigation Strategies

Section D – Validation Risk Structuring and Compliance Evidence Compilation (5 Marks)

Q4 (1): Validation Risk Register (2 Marks)

A Validation Risk Register is used to identify, analyze, and manage system risks.

Risk ID	Risk Description	Impact	Likelihood	Mitigation Strategy
R1	Unauthorized access to patient records	High	High	Implement Multi-Factor Authentication
R2	Data breach due to weak encryption	High	Medium	Use strong encryption methods
R3	Loss of compliance evidence	Medium	Medium	Maintain secure backups and audit logs